

Rendu individuel - Yvan FOCSA - V1

Architecture securite, infrastructure et industrialisation

Rendu individuel - Yvan FOCSA - V1

Informations generales

Champ | Valeur
Nom | FOCSA
Prenom | Yvan
Projet | Mise en place d'un SOC externalise pour un reseau d'audioprothesistes
Role | Architecte securite / infrastructure, flux reseau et industrialisation
Equipe | Yvan FOCSA, Youssef GUERNIOU, Kilyan FELIX, Mahamadou DIACOUNBA

1. Presentation de mon role

Dans ce projet, mon role principal est de contribuer a la conception de l'architecture securite du SOC externalise. Mon travail porte sur la structuration de la solution cible, la definition des flux entre les sites clients et le SOC central, l'organisation du perimetre MVP et la preparation de l'industrialisation vers plusieurs points de vente.

J'interviens aussi sur la coherence globale des livrables, notamment en reliant les choix techniques aux attentes du cahier des charges : collecte multi-source, interface web, dashboards, alertes, playbooks, reproductibilite et scalabilite.

2. Analyse du besoin client

Le besoin client part d'un reseau d'audioprothesistes compose d'environ 30 centres. Chaque site manipule des donnees sensibles, utilise des postes de travail metier, des applications CRM/RDV/dossiers patients, une messagerie professionnelle, des serveurs internes et des equipements reseau. La difficulte principale est que les evenements de securite sont disperses entre plusieurs sites et plusieurs briques techniques.

J'ai donc traduit le besoin client en exigences d'architecture :

Besoin identifie | Impact pour l'architecture | Reponse proposee
Manque de ressources cyber internes | Le client ne peut pas exploiter seul un SOC complet | SOC externalise cote prestataire.
Environ 30 points de vente | La solution doit etre reproductible et scalable | Modele MVP sur 3 sites representatifs, extensible par onboarding.
Donnees clients et dossiers patients | Les logs doivent aider a detecter les acces anormaux sans exposer de vraies donnees | Logs fictifs et scenario acces dossier patient.
Sources de logs heterogenes | Il faut collecter postes, firewall, applications, serveurs et messagerie | Collecte agents, syslog et logs applicatifs.
Besoin de lisibilite direction/SOC | Les alertes doivent etre exploitables et presentees clairement | Dashboards supervision, analyse et administration.
Besoin d'infogerance | Le deploiement doit etre standardise | Templates, conventions de nommage, checklist onboarding et guide.

Cette analyse montre que le sujet n'est pas seulement technique. Il faut proposer une solution comprehensible par un client, exploitable par un analyste SOC et suffisamment documentee pour etre reprise ou etendue.

3. Traduction technique des briques SI

J'ai aussi relie chaque brique SI du cahier des charges a un mode de collecte et a un risque supervise :

Brique SI | Risque principal | Mode de collecte MVP | Scenario ou preuve associee
Postes de travail | Execution suspecte, usage USB, compromission locale | Agent Wazuh ou logs endpoint rejoues | Alertes 100100 et 100140.
Routeurs / firewalls | Brute force, scan, acces non autorise | pfSense CE cible, FW-S01/FW-S02 et logs syslog simules dans le MVP | Alertes 100110 et 100160.
Applications metier | Acces anormal aux dossiers patients | Logs applicatifs JSON | Alerte 100120.
Serveurs internes / AD | Elevation de privileges, acces fichiers | Agent serveur ou logs AD simules | Alerte 100130.
Messagerie professionnelle | Phishing, piece jointe ou lien suspect | Logs mail simules | Alerte 100150 et playbook phishing.

Cette correspondance est importante pour defendre l'architecture : chaque composant du schema repond a un besoin de monitoring precise dans le cahier des charges.

4. Contributions principales

Mes contributions principales sont les suivantes :

Contribution | Description
Cadrage du perimetre MVP | Proposition d'un MVP representatif, limite a des sites simules pour prouver le modele avant extension.
Architecture SOC externalise | Definition d'une architecture centralisee autour de Wazuh, avec collecte depuis postes, firewalls, applications et serveurs.
Flux de collecte | Identification des flux agents, syslog et logs applicatifs.
Industrialisation | Preparation d'une logique de deploiement reutilisable pour passer du MVP a environ 30 sites.
Maitrise des couts | Analyse du choix open-source, des couts du MVP et des couts de production a anticiper.
Documentation | Contribution aux documents de cadrage, architecture, planning, matrice de conformite et rapport technique.
Video MVP | Preparation de la partie architecture, perimetre, scalabilite et conclusion.

5. Travail realise

J'ai d'abord analyse le cahier des charges afin d'identifier les attentes principales du client. Les briques a superviser sont les postes de travail, les firewalls, les applications metier, les serveurs internes et la messagerie. A partir de ces exigences, j'ai participe a la construction d'un perimetre MVP permettant de montrer une chaine SOC complete sans reproduire inutilement toute la complexite des 30 centres.

J'ai ensuite formalise l'architecture cible : un SOC externalise centralise, exploite par un prestataire, recevant les evenements de securite depuis les sites clients. Cette architecture repose sur Wazuh pour la collecte, l'indexation, la detection et la visualisation.

J'ai aussi valide l'approche Docker pour le MVP. Plutot que de monter immediatement plusieurs VMs lourdes, Docker permet de simuler les services, serveurs et sources de logs de maniere reproductible. Cette solution est adaptee a une demonstration, a condition de bien expliquer que les conteneurs representent un environnement de lab et que certains composants seraient remplaces par des postes, serveurs ou equipements reels en production.

J'ai aussi travaille sur l'industrialisation. L'objectif n'est pas seulement de faire fonctionner une demonstration, mais de montrer comment cette demonstration pourrait devenir une solution exploitable pour plusieurs sites. Cela implique une convention de nommage, des templates de deploiement, une checklist d'onboarding site, des dashboards filtrables et une documentation claire.

J'ai egalement contribue a la logique de maitrise des couts. Le MVP s'appuie sur Wazuh et des outils open-source afin de limiter les couts logiciels. Pour une production, les couts principaux seraient plutot l'infrastructure, le stockage des logs, l'exploitation SOC, la maintenance, les sauvegardes et l'onboarding des sites. La standardisation du deploiement permet donc de reduire le cout par centre.

6. Perspectives d'evolution de la solution

Plusieurs evolutions me semblent pertinentes pour renforcer la solution :

Evolution | Interet
Deploiement d'agents reels sur VMs | Rendre le MVP plus proche d'un environnement client.

Integration Suricata | Ajouter une detection reseau plus fine sur les flux suspects.
Ajout TheHive | Structurer la gestion des incidents sous forme de tickets.
Ajout Shuffle | Automatiser certaines actions de reponse simples.
Haute disponibilite Wazuh | Rendre la solution plus credible pour une production.
Reporting client automatise | Produire des rapports mensuels par site et globaux.
RBAC avance | Segmenter les droits supervision, analyste et administrateur.

L'evolution la plus importante est selon moi l'industrialisation du deployment. Pour superviser 30 sites, il faut reduire au maximum les actions manuelles : agents standardises, configuration syslog repetable, inventaire fiable et verification automatique de la collecte.

7. Limites techniques rencontrees

La premiere limite est liee au caractere demonstrateur du projet. Une partie des logs est simulee ou rejouee, ce qui permet d'obtenir une demo stable, mais ne remplace pas totalement un environnement de production avec utilisateurs, postes et applications reels.

La deuxieme limite concerne la supervision multi-sites. Le MVP valide la chaine technique, mais le passage a 30 sites demande un travail supplementaire sur le dimensionnement, la retention des logs, la bande passante, la haute disponibilite et le maintien en condition de securite.

La troisieme limite concerne les dashboards. Les alertes existent, mais la qualite finale de la demonstration dependra beaucoup des captures et de la lisibilite des vues Wazuh. Il faudra donc soigner les filtres par criticite, site, source et scenario.

8. Analyse critique personnelle

Avec du recul, le point le plus important dans ce projet est de ne pas se disperser. Un SOC peut rapidement devenir tres large : SIEM, IDS, EDR, SOAR, threat intelligence, ticketing, reporting, RBAC, forensic. Pour rester efficace, il faut d'abord prouver une chaine simple mais complete : collecte, detection, alerte, qualification, reponse, preuve.

Je pense que notre approche est pertinente parce qu'elle part d'un MVP raisonnable et documente. Elle permet de repondre au cahier des charges sans promettre une plateforme SOC trop ambitieuse pour le temps disponible.

En revanche, il faut rester vigilant sur la coherence entre la demonstration et le discours. Si nous parlons d'industrialisation vers 30 sites, nous devons montrer au minimum une methode claire : inventaire, checklist, conventions, templates, monitoring de la collecte et reporting.

9. Defis rencontres

Les principaux defis sont :

- transformer un cahier des charges assez large en perimetre MVP clair ;
- choisir une architecture suffisamment ambitieuse mais realisable ;
- relier les preuves techniques au rapport final ;
- eviter que les livrables soient seulement descriptifs ;
- preparer une demonstration stable meme si l'environnement technique rencontre des problemes.

Le defi le plus structurant est la coherence. Chaque element du projet doit pouvoir etre relie a une exigence du cahier des charges : une source de logs, une regle, une alerte, un dashboard, un playbook ou une preuve.

10. Forces personnelles mobilisees

J'ai mobilise plusieurs forces personnelles :

Force | Application dans le projet
Structuration | Organisation du perimetre, des roles, des documents et des livrables.
Vision architecture | Construction d'une solution cible comprehensible et scalable.

Esprit de synthese | Transformation du cahier des charges en exigences actionnables.
Sens de la documentation | Production de contenus reutilisables pour le rapport et la video.
Prise de recul | Identification des limites et perspectives d'evolution.

11. Faiblesses ou points d'amelioration personnels

Je dois encore progresser sur plusieurs points :

Point d'amelioration | Action possible

Aller plus vite vers la preuve technique | Produire des captures et tests des qu'une fonctionnalite marche.

Mieux prioriser | Distinguer plus rapidement le necessaire du bonus.

Approfondir Wazuh | Comprendre plus finement le parsing, les decoders et les dashboards.

Formaliser les flux reseau | Ajouter un tableau ports/protocoles plus detaille.

Anticiper la soutenance | Preparer plus tot le discours oral et les transitions.

12. Competences developpees

Ce projet m'a permis de developper plusieurs competences :

- analyse d'un besoin cyber complexe ;
- conception d'une architecture SOC externalisee ;
- definition d'un perimetre MVP ;
- documentation technique ;
- raisonnement sur la scalabilite et l'industrialisation ;
- comprehension des flux de collecte SIEM ;
- mise en relation entre logs, alertes, dashboards et playbooks ;
- preparation d'un livrable professionnel.

13. Ce qu'il me reste a faire techniquement

Ma partie architecture est documentee. Ce qu'il me reste a faire techniquement est surtout de verifier et presenter les preuves, pas de redevelopper les regles Wazuh.

Action restante | Priorite | Objectif

Montrer le schema d'architecture dans la video | Haute | Prouver mon role architecture et cadrage.

Montrer le dashboard global ou la liste des alertes | Haute | Relier l'architecture a un resultat visible.

Montrer la checklist onboarding | Haute | Prouver l'industrialisation vers plusieurs sites.

Expliquer les couts en 20 secondes | Moyenne | Montrer que le modele est defendable economiquement.

Verifier que les IDs d'alertes cites sont coherents | Haute | Eviter un ecart entre rapport, video, regles et captures.

Integrer les vraies captures Wazuh si disponibles | Haute groupe | Remplacer ou completer les captures de demontreteur.

Refaire le zip final apres lien video ou nouvelles captures | Haute groupe | Garder un depot final propre.

Exporter les schemas Mermaid en PNG si possible | Optionnel | Faciliter l'affichage pendant la video.

Techniquement, je dois surtout etre capable d'expliquer les flux suivants : agent Wazuh pour postes et serveurs, syslog pfSense CE pour firewall, logs applicatifs pour l'application metier, dashboard web pour les analystes, puis playbooks pour la reponse. Je dois aussi rappeler que les ports et protocoles seraient verrouilles en production par pare-feu, VPN ou filtrage reseau.

14. Axes d'amelioration pour de futurs projets

Pour un futur projet, je mettrais en place plus tot une logique de preuve continue. Chaque tache technique devrait produire immediatement une capture, un log, un extrait de configuration et une phrase de synthese pour le rapport.

Je formaliserais aussi un tableau de suivi unique avec quatre colonnes obligatoires : exigence, implementation, preuve, statut. Cela permettrait de verifier en permanence que le projet reste aligne avec le cahier des charges.

Enfin, je prevoirais des scenarios de secours pour la video. Dans un projet SOC, l'environnement peut etre

instable ; disposer de logs rejouables et de captures preparees est essentiel pour garantir une demonstration fluide.

15. Conclusion personnelle

Ma contribution au projet porte principalement sur la structuration et l'architecture. J'ai cherche a construire une solution credible, realisable et alignee avec le besoin client. Le SOC propose n'est pas seulement une installation Wazuh : c'est un modele de supervision externalisee qui peut etre documente, reproduit et progressivement industrialise.

La suite logique consisterait a consolider les schemas en images, maintenir les tableaux de flux, verifier les preuves visuelles dans le rapport et preparer une prise de parole claire pour la video MVP.